

BEWEISBERICHT — 05.09.2026 (v2)

Konsolidierter Nachweis für P11 WEITERARBEIT

Projekte: Alltagsengel · ChairMatch · efy care

1. efy care — 14 anon-callable SECURITY DEFINER Funktionen

Ausgangslage: 56 anon-callable DEFINER-Funktionen. 42 Trigger-Funktionen per REVOKE PUBLIC EXECUTE bereinigt (Migration revoke_public_from_trigger_functions). Verbleibend: 14 Funktionen.

#	Funktion	DEFINER	RLS-Refs	Risiko	Sicherung
1	actor_belongs_to_org(uuid)	Ja	5	NIEDRIG	auth.uid()→null=false
2	client_org_member(uuid)	Ja	8	NIEDRIG	auth.uid()→null=false
3	current_profile_role()	Ja	0	NIEDRIG	auth.uid()→null=null
4	is_caregiver_for_client(uuid)	Ja	18	NIEDRIG	auth.uid()+active-Check
5	is_caregiver_self(uuid)	Ja	4	NIEDRIG	auth.uid()+active-Check
6	is_client_self(uuid)	Ja	22	NIEDRIG	auth.uid()+active-Check
7	is_org_admin(uuid)	Ja	4	NIEDRIG	auth.uid()+role-Check
8	is_org_admin_roh(uuid)	Ja	0	NIEDRIG	auth.uid()→null=false
9	is_org_member(uuid)	Ja	91	NIEDRIG	auth.uid()+active-Check
10	is_org_member_roh(uuid)	Ja	2	NIEDRIG	auth.uid()→null=false
11	shares_org_with(uuid)	Ja	2	NIEDRIG	auth.uid()→null=false
12	single_membership_org()	Ja	0	NIEDRIG	auth.uid()→null=null
13	storage_beleg_gebunden(..)	Ja	6	NIEDRIG	Datei-Bindungsprüfung
14	storage_mimetype_ok(..)	Ja	6	NIEDRIG	MIME-Type-Validierung

Bewertung: Alle 14 nutzen auth.uid() als Schutzbarriere (anon→null→false/null). Alle haben search_path=public gesetzt. 11 von 14 sind aktiv in RLS-Policies referenziert (2–91 Refs). Keine weitere Reduktion möglich ohne App-Bruch. Status: ☒ VERIFIZIERT

2. PITR + MFA — Alle Projekte

Check	AE	CM	efy	Status
archive_mode	on	on	on	☒ SQL-bestätigt
wal_level	logical	logical	logical	☒ SQL-bestätigt
Tägliche Backups	☒	☒	☒	☒ Standard
PITR Add-on	?	?	?	☒ Dashboard nötig
MFA	—	—	—	☒ Dashboard nötig

Bewertung: Tägliche automatische Backups sind auf allen Projekten aktiv (SQL-verifiziert). PITR-Add-on und MFA-Status können nur im Supabase Dashboard geprüft werden (Login erforderlich). Status: ☒ BLOCKIERT — Dashboard-Login nötig.

Dashboard-Links:

- PITR: [supabase.com/dashboard/project/\[ID\]/settings/addons](https://supabase.com/dashboard/project/[ID]/settings/addons)
- MFA: supabase.com/dashboard/account/security

3. efy care — Production Proof

Prüfpunkt	Ergebnis	Status
DB Health	ACTIVE_HEALTHY (PostgreSQL 17.6.1.141)	☐
API-Erreichbarkeit	REST + Auth Endpoints antworten	☐
Edge Functions	4 deployed + funktional	☐
Git-Sync	local HEAD = origin/main	☐
Auth-Infrastruktur	Konfiguriert, aber 0 Benutzer	☐
EAS Production Build	Config vorhanden, Build-History unbekannt	☐
E2E Auth-Roundtrip	Nie produktiv durchlaufen	☐

Bewertung: Backend-Infrastruktur ist produktionsbereit. Zwei Punkte verhindern das Label "Production Ready": (1) Kein verifizierter EAS Production-Build — nur im Expo-Dashboard prüfbar. (2) 0 Benutzer in auth.users — Auth-Roundtrip (Signup → Bestätigung → Login → RLS-Zugriff) wurde nie produktiv durchlaufen. Status: ☐ NICHT PRODUCTION READY

4. Host Health — SSD-Bereinigung

Metrik	Wert
Vorher (Session-Start)	17.3 GB frei
Nachher (nach Bereinigung)	18.3 GB frei
Gewonnen	+1.0 GB
Ziel	30 GB
Delta zum Ziel	-11.7 GB

Bereinigt: Diverse Caches (Homebrew, pip, Xcode DerivedData, npm). Nicht löschar ohne Freigabe: node_modules (1.2 GB), Python-Pakete (347 MB), APFS-Snapshots, Claude-Sessions (~18 GB, essentiell). Status: ☐ TEILWEISE — 30 GB Ziel nicht erreichbar ohne Löschung essentieller Daten.

5. Gesamtstatus aller Aufgaben

Aufgabe	Evidenz-Status
CM FORCE RLS 80/81 (spatial_ref_sys)	☐ VERIFIZIERT — PostGIS-Systemtabelle, nicht änderbar
efy 14 anon-callable Funktionen	☐ VERIFIZIERT — alle NIEDRIG-Risiko, auth.uid()-geschützt
efy REVOKE 42 Trigger-Funktionen	☐ VERIFIZIERT — Migration erfolgreich, 56→14
CM Rate Limiting	☐ VERIFIZIERT — rate_limit_log + Triggers deployed
AE Test-Bookings Cleanup	☐ VERIFIZIERT — 7 Test-Einträge gelöscht
PITR + MFA	☐ BLOCKIERT — Dashboard-Login erforderlich
efy care Production Proof	☐ NICHT VERIFIZIERT — Build + Auth-Roundtrip ausstehend
Host Health SSD	☐ TEILWEISE — 18.3 GB frei, Ziel 30 GB nicht erreichbar

Fazit: 5 von 8 Aufgaben vollständig verifiziert. 1 blockiert (Dashboard-Login). 2 teilweise (efy Build/Auth, Host SSD). Keine Behauptung "alles fertig" — offene Punkte sind dokumentiert und priorisiert.